

TECHNICAL WHITEPAPER · TRUST INFRASTRUCTURE

The root of digital trust

Why verifying a foreign digital signature is still hard, and how a public mirror of national PKI trust anchors solves it.

An open directory, continuously expanding
trust.attestto.org

ffd7cbc2fa40ac74a034729d4d69245ae01731397373d1cddd984651d255e4a9
efd4f9f6b7ad5929688797bc016e0b9b82b3dd21d810f8d3e24b0be5302461f7
70e1af0a203597b53c0fa122f4b2a4cc4a112fe3c2fa240fe2d4f0dbd241050b
4f4ea2e728ebf9a15320c32dd7fce7bfc9777a7cd140c1fc7f87360fc7475af8
959569fa8764425fa9f13ea7767456283ff2cc98c99147e337744dfb1248821a
d0c9fc4311cd7bebc26ce0ceaa85b3871d96c97ba564fc4c616aa3daad017f24
fdac9f6527ef2f46db1bfcd655811e15504837309b5f57f545661546bf4fa9b8

Executive summary

Validating a digital signature issued in your own country is usually trivial. Validating one issued elsewhere rarely is.

The reason is not cryptographic. Signature algorithms and formats have been standardised for decades. The obstacle is distribution: to verify a signature you must trust the root certificate behind the chain, and every country publishes its roots differently — on a ministry portal, in a PDF annex, inside an XML list with hundreds of entries, sometimes on a page that moves without notice.

The outcome is predictable. Engineering teams end up copying certificates of uncertain origin, pinning them in code, and finding out they expired when an integration breaks in production. In the worst case, accepting chains they never fully verified.

Attestto Trust is an independent public mirror of national PKI trust anchors. It mirrors the root and intermediate certificate authorities behind national digital signature systems and presents them as a clear, verifiable hierarchy: each certificate with its SHA-256 fingerprint as tamper evidence, its validity window, and a direct download of the original *.pem*.

The same information is available in three forms: a page readable by people, an npm package to pull into a build, and a `did:pki` resolver for programmatic lookup. Attestto's public document verifier runs on that foundation, and its reach grows with every jurisdiction added to the mirror.

What this paper covers

- Why trust anchor distribution is an unsolved problem.
- The anatomy of a national hierarchy, with Costa Rica as a worked example.
- The contrast between eIDAS in Europe and the absence of an equivalent framework in Latin America.
- Organisational identity: GLEIF's vLEI, *did:keri* and *did:webs*.
- Technical integration and the explicit limits of the service.

SECTION 1

The scattered anchor problem

A digital signature only means something if it can be traced to a root you decided to trust. That root — the **trust anchor** — is a self-signed certificate the verifier accepts as a starting point. Everything else hangs from it: intermediate certificates, signer certificates, timestamps.

The cryptography of that chain is settled. What is not settled is how a system obtains the right root, knows it is the right one, and finds out when it changes.

How anchors are distributed today

Browsers and operating systems ship trust stores for TLS, curated by their vendors. But the roots behind *qualified* digital signatures — the ones backing a person's or a company's legal identity before the state — are almost never in those stores. They are published through each jurisdiction's own channels.

- In the European Union, eIDAS Trusted Lists exist: signed XML lists maintained by each member state's supervisory body. They are authoritative and machine-readable, but bulky and awkwardly structured.
- In Latin America there is no regional equivalent. Each country publishes its roots wherever it sees fit, with differing formats and availability.
- In both cases, finding the right certificate requires knowing in advance which body is competent in that country — information the person doing the integration rarely has at hand.

The problem is not that the data is secret. It is public. The problem is that it is scattered, heterogeneous, and has no common way to be cited.

Three failure modes

1. Pinning without verifying. The certificate is copied from a forum, a third-party repository or an email attachment, and added to the project without checking its fingerprint against the official source. If the origin was compromised, verification is hollow: a signature is checked against an anchor that is not the

one assumed.

2. Expiring silently. Roots and intermediates have long validity windows, from eight to twenty-five years. That duration creates a false sense of permanence: nobody monitors something that expires a decade out, until it expires.

3. Confusing generations. This is the subtlest failure. Issuing authorities are renewed periodically while keeping the same common name, so several distinct generations coexist under one name with different keys. A system that matches by name will pick the wrong one sooner or later.

The fingerprint as identifier

The answer to all three is the same: identify every certificate by its **SHA-256 fingerprint** rather than its name. The fingerprint is unique, unambiguous across generations, and independently verifiable against the official source. It is what turns a copy into evidence.

SECTION 2

Anatomy of a national hierarchy

Costa Rica is a particularly clean illustration of how a national PKI is structured, because it uses the **single hierarchy** model: one root from which the whole system descends, with no cross-certification and no competing anchors.

The root is CA RAIZ NACIONAL – COSTA RICA v2, with a validity window from 2015 to 2039, operated by the Central Bank of Costa Rica through SINPE under MICITT accreditation, whose Directorate of Digital Signature Certifiers (DCFD) acts as the accrediting body. The governing law is Ley 8454, with RSA-4096 throughout and support for the CAdES, PAdES and XAdES advanced signature formats.



Ten certificates: one root and nine intermediates. Source: Attestto Trust directory, as of 23 July 2026.

Three levels, three functions

Root. The anchor itself. Self-signed, with the longest window and the most protected key. It is the only certificate a verifier must obtain out of band and confirm by fingerprint.

Policy. An intermediate tier separating uses: natural person, legal person and timestamping each have their own policy CA. That separation contains the blast radius of an incident and allows different rules per certificate type.

Issuing. The SINPE CAs that actually sign end-user certificates, plus specific issuers such as the Central Bank's own electronic agent.

The overlapping generations case

The Costa Rican hierarchy illustrates the third failure mode plainly. Under the natural-person policy CA, **three** issuers coexist named exactly *CA SINPE – PERSONA FISICA v2*, with different keys and serial numbers, expiring in 2027, 2031 and 2034.

Three certificates, one name. Any validation logic that matches on common name will pick the wrong generation. Only the fingerprint tells them apart.

Revocation

A certificate's validity does not depend on its time window alone: it may have been revoked. Costa Rica exposes an OCSP responder at *ocsp.sinpe.fi.cr*, and the BCCR maintains validation and revocation lookup services through Central Directo. An anchor directory does not replace that live query; it complements it by supplying the chain material the query is built on.

SECTION 3

eIDAS and the regional asymmetry

The directory's coverage reveals a contrast worth making explicit, because it explains much of the friction Latin American teams run into.

The European model

Under the eIDAS regulation, each member state designates a supervisory body that maintains and publishes a national *Trusted List*: a signed XML document listing qualified trust service providers and their certificates. The European Commission aggregates those lists into a list of lists, making the whole set theoretically resolvable automatically.

In the directory, European countries appear under their supervisory bodies: AgID in Italy, Bundesnetzagentur in Germany, ANSSI in France, EETT in Greece, RDI in the Netherlands, RTR in Austria, FPS Economy in Belgium, GNS in Portugal, RIA in Estonia and FNMT-RCM in Spain.

The volume is substantial: Italy alone contributes more than two hundred certificates, and Greece, Germany and France each exceed seventy. That abundance reflects an open market of qualified providers, and explains why navigating a Trusted List by hand is impractical.

The Latin American model

The region operates closed national hierarchies with state accreditation, and has no equivalent to European mutual recognition. The directory lists Costa Rica under MICITT/DCFD, Peru under INDECOPI within the IOFE framework, Brazil under ITI, and Argentina under the Root CA of the Chief of Cabinet's Office. Each publishes a handful of certificates rather than dozens: a single hierarchy concentrates issuance in one state operator instead of distributing it across accredited providers.

Italy lists 231 certificates and Greece 105; Costa Rica, 10, and Peru, 8. The asymmetry does not measure maturity: it measures architecture. Closed hierarchies versus open provider markets.

What it means in practice

For an integrator, the difference feels like this: in Europe the problem is **volume and filtering** — there is too much, and you must select. In Latin America the problem is **location and stability** — there is little, but it is hard to find and not always where it was.

A single directory with a homogeneous structure, consistent metadata presentation and a common download format serves both cases through the same interface, without every team reimplementing access to each national scheme.

SECTION 4

Directory coverage

The figures below are a snapshot. The current and authoritative list is always the one on the site.



Regions and publishing authorities

Representative authorities by region; not the complete listing.

Region	Publishing authorities
Central America	Costa Rica — MICITT / Directorate of Digital Signature Certifiers (DCFD)
South America	Argentina — Chief of Cabinet's Office (Root CA) · Brazil — ITI · Peru — INDECOPI (IOFE)
Northern Europe	Estonia — RIA (Riigi Infosüsteemi Amet)
Western Europe	Austria — RTR · Belgium — FPS Economy · France — ANSSI · Germany — Bundesnetzagentur · Netherlands — RDI
Southern Europe	Greece — EETT · Italy — AgID · Portugal — GNS (SCEE) · Spain — FNMT-RCM (Ceres)
Global organisational identity	GLEIF — vLEI, with associated qualified issuers (<i>did:keri</i> , <i>did:webs</i>)

What each country page shows

Every jurisdiction also declares its trust model, the governing law, key algorithms, supported signature formats and the currency of the revocation snapshot. Costa Rica: national hierarchy, Ley 8454, RSA-4096, CAdES / PAdES / XAdES, with natural person, legal person, timestamping and electronic seal capabilities. That metadata lets you judge the freshness of the data **before** relying on it.

A growing directory

Coverage expands in two directions. By **breadth**, as new jurisdictions are added. And by **depth**, because already mirrored authorities issue, renew and retire certificates continuously.

A useful directory cannot be static: this printed copy does not replace the live lookup.

SECTION 5

Organisational identity: the vLEI anchor

Alongside the national anchors, the directory keeps a category of its own — *global organisational identity* — headed by GLEIF's vLEI, with its qualified issuers and the associated *did:keri* and *did:webs* identifier methods. It hangs from no jurisdiction because it answers to none: its scope is global by design.

What the vLEI is

The vLEI — *verifiable LEI* — is the cryptographic counterpart of the Legal Entity Identifier. Where the LEI is a 20-character code looked up in a public index, the vLEI is a verifiable credential that lets an organisation — or a person acting on its behalf — prove that identity cryptographically, without depending on a registry lookup at verification time.

The associated identifiers are *did:keri* and *did:webs*, built on KERI, a self-certifying identifier model whose authority derives from key rotation recorded in the identifier itself rather than from a central registry.

Why they belong in the same directory

Because they answer the same question from complementary angles. A national PKI attests *who this person or entity is before this state*. The vLEI attests *which organisation this is globally, and who may act in its name*.

In a cross-border corporate onboarding file, both pieces are needed: the national qualified signature proves the act; the global organisational identity proves the signing entity is who it claims to be outside its own jurisdiction.

A concrete example

A Costa Rican entity signs a contract with a legal-person certificate issued under the BCCR hierarchy. The European counterparty can technically validate that signature given the national root — which the directory supplies with a verifiable fingerprint — but that says nothing about whether the signing company is the parent, a subsidiary or a namesake.

The LEI and its verifiable expression cover that second dimension. The combination — national anchor for the validity of the act, organisational identity for the identity of the party — is what makes a complete cross-border verification defensible.

Scope note. Attestto is not a certification authority, does not issue certificates, and is not a GLEIF-accredited Local Operating Unit. The directory mirrors and structures public data published by each authority.

SECTION 6

Technical integration

The same data, three surfaces: readable by people, importable at build time, resolvable over an API.

npm package

[@attestto/trust](#) pulls the anchors and per-country manifests into the build process, instead of downloading certificates by hand and versioning them as loose files.

```
$ npm install @attestto/trust

# per-country manifests, ready for validation
```

did:pki resolver

The [did:pki resolver](#) exposes the same anchors as the machine and API face, allowing programmatic resolution and verification against them. It is the natural route when validation happens at runtime rather than at build time.

Certificate detail

Every certificate has its own page with the **trust chain** from the root and the **certificate fields**: subject and issuer, role, key algorithm, validity with days remaining, dates with UTC stamps, serial number and SHA-256 fingerprint. It supports auditing without downloading.

Direct download

Each certificate offers its original *.pem* alongside the fingerprint that confirms the downloaded file is the one published by the authority. For one-off integrations or manual audits it remains the most direct route.

Recommended usage pattern

- Obtain the anchor from the directory and **check its SHA-256 fingerprint against the publishing authority's official source** before first use.
- Pin the anchor by fingerprint rather than common name, to avoid collisions between generations of one issuer.
- Record each anchor's validity window and alert well ahead of expiry.
- Check revocation through the authority's OCSP or CRL: the directory supplies the chain, not the real-time status.
- Re-verify periodically against the official source: a mirror is a convenience, not a delegation.

SECTION 7

Scope and limits

The usefulness of a trust anchor mirror depends on stating its limits precisely. A directory presenting itself as an authority would invite exactly the behaviour it sets out to correct: trusting without verifying.

What it is	What it is not
✓ An independent public mirror	A certification authority
✓ Mirrors and structures data published by each national PKI	Issues certificates or credentials
✓ Publishes the SHA-256 fingerprint as tamper evidence	Replaces verification against the official source
✓ Supplies chain material to build validation on	Answers for real-time revocation status
✓ Links to each jurisdiction's official publishing authority	Accredits, supervises or rates those authorities
✓ Offers the data in readable and programmatic form	Guarantees the completeness of any national list

The operating instruction is always the same: always verify against the authoritative official source. The directory exists to make that verification possible and fast, not to avoid it.

The directory and what is built on it

Attestto also operates a document verifier that consumes this directory (Section 9). The distinction is worth keeping: the mirror is public infrastructure, with open data anyone can verify; the verifier is a product built on that infrastructure, just as a third party could build one. The existence of one grants the other no standing as an authority, and the directory's data remains independently checkable against the official source.

Why independence matters

A mirror operated by a third party with no accrediting function has a useful property: it does not compete with the authorities it mirrors, nor has any incentive to present their data selectively. Its value lies in the fidelity of the copy and the clarity of the presentation, both checkable by anyone comparing the published fingerprint against the original certificate.

SECTION 8

Use cases

The directory does not solve a new problem. It solves an old one that every team had been solving on its own, with uneven results.

Validating signed documents

Electronic signature platforms, document management systems and case file systems receiving documents signed across several jurisdictions need complete chains to validate. Without a common source, every new jurisdiction admitted means researching where that country publishes its roots, and maintaining that finding over time.

The case gets worse with long-term validation. A document signed today may need verifying ten years out, when the intermediate that issued it has expired and the authority has perhaps reorganised its site. Preserving the chain with its fingerprints at signing time is part of the record, not an implementation detail.

Cross-border onboarding and KYB

When a corporate client supplies documentation digitally signed in its home jurisdiction, being able to validate that signature — rather than accepting an unverified PDF — substantially raises the quality of the evidence.

The difference matters to a supervisor. A file recording which anchor was used, with which fingerprint and on what date, is verifiable by a third party; one that only stores the received document is not.

Public sector and interoperability

Administrations receiving filings from foreign residents or companies face the same problem in reverse, with less room to manoeuvre: they cannot reject a valid filing because they do not know how to validate the signature. A common anchor source cuts the integration work for each jurisdiction they decide to accept.

Audit and forensics

In a later review — internal audit, inspection, litigation — reconstructing the trust chain in force on the signing date requires access to certificates that may already have expired, and certainty about which of several same-named generations was active then. A directory with explicit validity windows and published fingerprints turns that reconstruction into a lookup.

Product development

For teams building on digital identity, having the anchors as a versioned dependency rather than hand-copied files changes the nature of the problem: from a recurring manual chore to a managed dependency, with change history and peer review like any other.

Expiry monitoring

Published validity windows make it possible to build alerts before an intermediate expires. It is the cheapest control on this list and the one that prevents the most incidents, because a CA expiry does not fail partially: it fails at once and for everything.

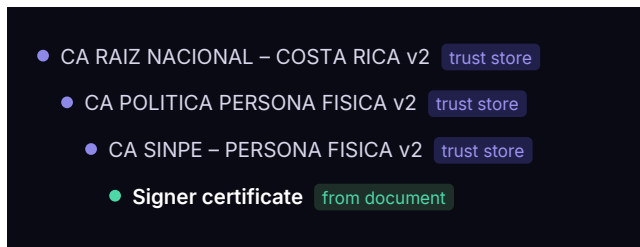
The common denominator across all these cases is the same: replacing an uncertain search with a reproducible lookup.

SECTION 9

The directory in use

The proof that a trust layer works is that something rests on it. Attestto operates a public verifier for signed documents that consumes the directory as its trust store: every anchor it validates a chain against comes from the same mirror described in the preceding sections.

The verifier's reach is, by construction, the directory's reach. Each jurisdiction added to the mirror becomes verifiable immediately, with no additional integration work, and the same applies to vLEI-based organisational identity.



Chain resolved by the verifier. The three anchors come from the directory; only the signer certificate travels inside the document.

What it solves in practice

The generations problem. In the example, the selected issuer is the generation of *CA SINPE – PERSONA FISICA v2* valid between 2023 and 2031 — one of the three same-named certificates described in Section 2. Resolving by fingerprint rather than name is what allows the correct one to be chosen unambiguously.

Revocation with a timestamp. The result does not merely assert that the certificate is not revoked, but when that was checked against the revocation list. A verification without a lookup date is not evidence; it is an opinion.

Signature context. Issuing jurisdiction, signing date, certificate validity and declared capabilities — document signing, non-repudiation, email protection — are presented alongside the result, because a valid certificate used outside its capabilities does not sustain the act.

Long-term validity. The verifier distinguishes between a signature that is valid today and one that will still be verifiable once its chain expires. Flagging that difference matters more than hiding it: it is the warning that prevents discovering the problem ten years too late.

Data minimisation

The signer's national identification is masked by omission, with on-demand checking. Verifying a signature should not require exposing the signer's document number to anyone who opens the result.

Conclusion

Qualified digital signatures work. What fails, routinely, is the step before: obtaining the right anchor, knowing it is the right one, and keeping it current.

That step is not fixed with more cryptography but with better distribution. Public data, homogeneously structured, identified by fingerprint, with visible validity windows, available for both human reading and programmatic consumption.

Attestto Trust occupies exactly that space, and no more: an independent public mirror that does not issue, does not accredit and does not replace the official source. Its purpose is to stop verification against that source from being an obstacle.

That a document verifier runs on this foundation — and that its reach grows with each jurisdiction added, with no per-country integration work — is the best evidence that the problem was in distribution and nowhere else.

Next steps

Review the directory's coverage for the jurisdictions you operate in and compare the published fingerprints against the certificates your organisation has in production today. It is a short exercise that routinely surfaces anchors pinned without verification, confused generations, or upcoming expiries with no monitoring.

Explore the directory.

trust.attestto.org · [npm install @attestto/trust](https://npmjs.com/package/@attestto/trust)

Document verifier: verify.attestto.com

The project is open, and contributions — corrections, new jurisdictions, reports of changes at official sources — are welcome through the [public repositories](#) and the [Discord](#) community.

Glossary

Term	Definition
Trust anchor	A root certificate a verifier accepts as the starting point of a chain of trust.
PKI	Public key infrastructure. The set of authorities, policies and procedures that issue and manage digital certificates.
Root CA	A self-signed certification authority at the top of a hierarchy.
Intermediate CA	A subordinate authority inheriting trust from the root and issuing to lower tiers.
SHA-256 fingerprint	A cryptographic digest that uniquely identifies a certificate and reveals any alteration.
Validity window	The period between a certificate's start and expiry dates.
.pem	A text file format for certificates, Base64-encoded between delimiters.
OCSP	Online protocol for checking a certificate's revocation status.
CRL	Certificate revocation list, published periodically by an authority.
eIDAS	The European regulation on electronic identification and trust services; establishes national Trusted Lists.
Trusted List	The signed XML list each EU member state publishes with its qualified trust service providers.
CAdES / PAdES / XAdES	Advanced electronic signature formats for binary data, PDF documents and XML documents respectively.
SINPE	The Costa Rican Central Bank's national electronic payment system, operator of the national digital signature hierarchy.
MICITT — DCFD	Costa Rica's Ministry of Science, Innovation, Technology and Telecommunications and its Directorate of Digital Signature Certifiers, the accrediting body.
LEI	Legal Entity Identifier. A 20-character code under ISO 17442 that uniquely identifies a legal person.
vLEI	The verifiable expression of the LEI as a cryptographic credential, associated with the did:keri and did:webs methods.
DID	Decentralised identifier. An identifier resolvable to a document with associated cryptographic material.

Sources and resources

- Attestto Trust — PKI trust anchor directory. trust.attestto.org
- Attestto — public document verifier. verify.attestto.com
- npm package — [@attestto/trust](https://www.npmjs.com/package/@attestto/trust), for build-time integration.
- did:pkg resolver — [public repository on GitHub](https://github.com/attestto/public-repository).
- BCCR — Firma Digital and validation services. bccr.fi.cr/firma-digital
- MICITT — Directorate of Digital Signature Certifiers. micitt.go.cr
- Costa Rica — Ley 8454 on Certificates, Digital Signatures and Electronic Documents.
- European Union — eIDAS Regulation and national trusted lists published by supervisory bodies.
- GLEIF — vLEI and the verifiable credential ecosystem. gleif.org
- ISO 17442 — Financial services: Legal Entity Identifier scheme.
- ETSI — CAdES, PAdES and XAdES advanced electronic signature specifications.

Attestto Trust is an independent public mirror of national PKI trust anchors. It is not a certification authority and does not issue certificates. The certificates shown are public data published by each national PKI; each entry lists its SHA-256 fingerprint as tamper evidence. Always verify against the authoritative official source. This document is informational and does not constitute technical or legal advice. Coverage figures are as of 23 July 2026 and change as each authority updates. Trademarks and names cited belong to their respective owners.

© 2026 Attestto. All rights reserved.